FIVUCSAS

Face and Identity Verification Using Cloud-based SaaS

Multi-tenant biometric authentication with active-liveness anti-spoofing

Ahmet Abdullah Gültekin **Ayşe Gülsüm Eren** **Ayşenur Arıcı**

Advisor: Assoc. Prof. Dr. Mustafa Ağaoğlu · CSE4197 / CSE4198 · Spring 2025–2026

Marmara University · Faculty of Engineering · Department of Computer Engineering

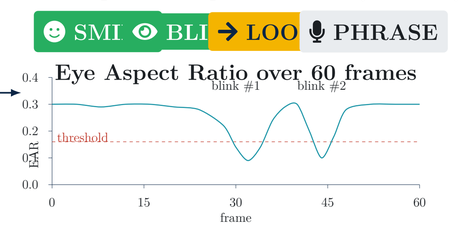
0 %	< 1 s	10
Replay-attack false-accept	End-to-end face verification	Composable auth factors
on $n = 120$ recorded-video attempts	commodity CPU, P95 = 950 ms	face + voice + NFC + WebAuthn + …

The Biometric Puzzle – active-liveness challenge

Step 1. Capture

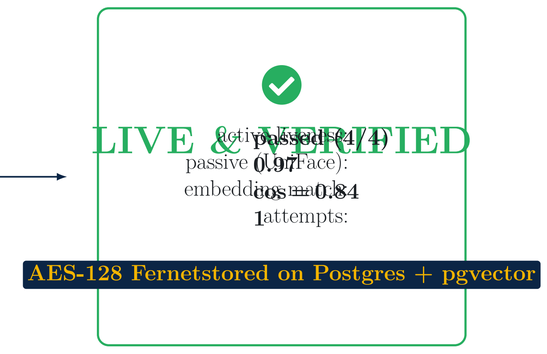
face-mesh tracking

random per-attempt action set (n = 3–5)



Step 2. Verify actions

landmark + temporal checks



Step 3. Encrypt + persist

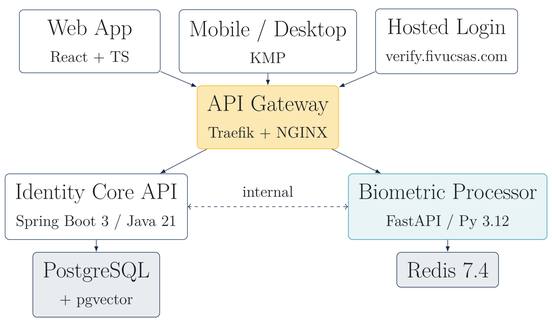
return verdict

1. Problem Statement

Online authentication is fragmented: passwords leak, SMS OTPs are SIM-swappable, hardware keys exclude phone-only users, and most biometric services trust a *single passive* signal — a still selfie or a recorded clip — that a prepared attacker can replay. Meanwhile GDPR / KVKK demand verifiable consent, the right to erasure and explicit data portability; consumer auth stacks treat these as an afterthought.

Goal. A **tenant-configurable**, **multi-modal** identity platform where any subset of ten authentication factors composes into MFA flows, and where every biometric factor is protected by an *active*, randomised liveness challenge a recorded video cannot replay.

2. System Architecture



Biometric service has no public route — Docker network only, API-key gated.

3. Passive vs. Active Liveness

Passive only

single frame → texture / colour cues.

- Photo of phone screen *often passes*
- Recorded clip *passes*
- Deepfake injection *often passes*

Active challenge

random n-step facial-action sequence + landmark verification + passive layer.

- Photo *fails*
- Recorded clip *fails (sequence mismatch)*
- Deepfake *much harder* — *must hit cues live*

4. Contributions

C1. Tenant-configurable composition of 10 authentication factors into MFA flows declared at the admin layer per tenant.

C2. Active randomised liveness — per attempt the server emits an n-step facial-action sequence (n=3–5) bound to a nonce; the client returns a 60-frame landmark stream; the server verifies each action against EAR / MAR / yaw and temporal consistency, in parallel with a UniFace MiniFASNet passive spoof check.

C3. Pipeline decomposition along the OIDC-contract / ML-iteration boundary into a Spring Boot identity-core and a FastAPI biometric-processor, isolated on a Docker network and gated by an internal API key.

C4. Embedding-at-rest encryption — Facenet512 embeddings wrapped in Fernet (AES-128-CBC + HMAC-SHA-256) prior to write into pgvector; HNSW search path operates on plain vectors only inside the trusted process.

C5. Regulator-aware data lifecycle — tenant-scoped soft-delete, scheduled purge, and audit-logging satisfying GDPR Art. 15 / 17 and KVKK equivalents.

5. How It Works (Methods)

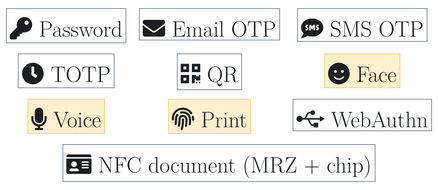
A monolithic auth service was rejected early: biometric ML changes weekly, but the OAuth / OIDC contract must remain frozen. The system is split along that boundary into two horizontally-scalable services on a private Docker network.

Per verification attempt:

1. Server issues a randomised action sequence $n=3-5$ + nonce.
2. Client streams 60-frame landmark vectors (MediaPipe FaceLandmarker, 468 points).
3. Server checks each action against EAR / MAR / yaw thresholds + temporal consistency.
4. UniFace MiniFASNet runs a passive spoof check in parallel.
5. Embedding (Facenet512) encrypted with Fernet (AES-128-CBC + HMAC-SHA-256) and matched against the user vector in pgvector (HNSW).

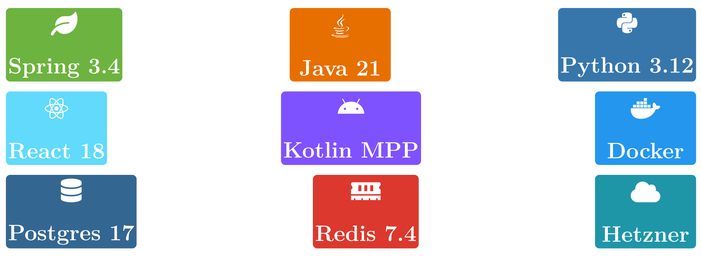
Engineering process. 60 Flyway migrations, 5 Git submodules, self-hosted GitHub runner on a single Hetzner CX43 VPS, 1 820+ tests gating every PR, 8 ADRs tracking architectural decisions.

6. Authentication Factors

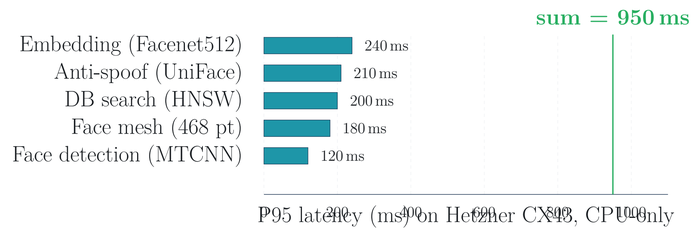


Gold tiles = wrapped in active-liveness; any subset is composable into a tenant MFA flow.

7. Technology Stack



8. Experiments and Results



End-to-end face-verification budget. Measured on the live production deployment.

Quality metric	Target	Observed
Replay-attack FAR ($n=120$)	< 1 %	**0.0 %**
Passive-spoof AUC (internal)	> 0.95	**0.97**
Backend tests	green	633 / 633
Web Vitest + Playwright	green	619 + 27
Mobile (KMP) units	green	425 / 425

9. Conclusion

Production-grade, GDPR-compliant biometric authentication *is* achievable on commodity hardware when the system is decomposed along its right axis (OIDC contract vs. ML model) and when liveness is treated as an active, challenge-driven property rather than a passive signal alone. Measurements on the deployed system indicate the latency budget (P95 = 950 ms on a single CPU server) and spoof-defence profile (0 / 120 replay-attack false-accepts, 0.97 passive-spoof AUC) are within practical limits for a tenant-shared platform.

10. Future Work

- **BYOD tenant DB.** Enterprise tenants host biometric data in their own database, schema-pinned.
- **On-device pre-filter.** Stripped MediaPipe pipeline drops obvious non-faces before upload — bandwidth + privacy win.
- **Cross-modal challenge.** Combine voice nonce + facial action to defeat audio-only deepfakes.
- **Verifiable credentials.** Issue W3C VCs after successful KYC for downstream-service portability.

11. Live Demo & References

Scan for live demo
`verify.fivucsas.com`

[1] Serengil, S., Özpınar, A. *LightFace / DeepFace.* IEEE ASYU, 2020.
[2] Lugaresi, C. et al. *MediaPipe: A Framework for Building Perception Pipelines.* arXiv:1906.08172.
[3] Soukupová, T., Čech, J. *Real-Time Eye Blink Detection using Facial Landmarks.* CVWW, 2016.
[4] Wan, L. et al. *Generalized End-to-End Loss for Speaker Verification.* ICASSP, 2018.
[5] Yadav, S. et al. *UniFace: A Unified Architecture for Face Spoofing Detection.* CVPR-W, 2023.